

Stored XSS into HTML Context with Nothing Encoded

Lab

PortSwigger Web Security Academy

Vulnerability

Stored Cross-Site Scripting (XSS)

Injection Point

Comment Box

Payload Used

```
<script>alert(1)</script>
```

Description

The application's comment functionality was vulnerable to **Stored XSS**.

A JavaScript payload was entered into the comment box and submitted. The application stored the malicious input and rendered it back as part of the page content.

When the affected page was loaded, the injected JavaScript executed and displayed an `alert(1)` popup, confirming the Stored XSS vulnerability.

Proof of Concept

The following payload was submitted through the comment box:

```
<script>alert(1)</script>
```

The successful execution of the JavaScript alert confirmed that the injected script was stored and executed when the comment was rendered.

Impact

An attacker could potentially:

- Execute JavaScript in a victim's browser
- Modify webpage content
- Perform actions in the context of the vulnerable application
- Access data available to JavaScript under the application's origin

Root Cause

The application stored and rendered user-controlled comment content without proper HTML encoding or sanitization.

Remediation

- Apply proper output encoding when rendering comments
- Sanitize user-controlled HTML input
- Prevent execution of untrusted scripts
- Implement an appropriate Content Security Policy (CSP)

Classification

CWE: CWE-79 — Improper Neutralization of Input During Web Page Generation

OWASP: Cross-Site Scripting (XSS)

Type: Stored XSS

Injection Point: Comment Box

Evidence

The vulnerability was confirmed by the successful execution of the `alert(1)` payload after the comment was submitted and rendered.

Status

Lab Solved

Platform: PortSwigger Web Security Academy

